

Prepared for: Bincom Academy Cybersecurity Program (Assignment 2) **Date:** April 21, 2026
Target IP Address: 10.0.2.15 (Metasploitable 2)

A vulnerability assessment and authorized exploitation simulation were conducted against a local target environment (Metasploitable 2). The objective was to identify misconfigurations or outdated software, exploit a critical vulnerability, and provide actionable remediation steps. The test resulted in a successful compromise, granting root-level (administrative) access to the target system.

Tool Utilized: Nmap with Nmap Scripting Engine (NSE) **Scanning Methodology:** A comprehensive service and version detection scan (**-sV**) coupled with the vulnerability script engine (**--script=vuln**) was executed against the target.

- **Vulnerable Service:** FTP (Port 21)
- **Software Version:** vsftpd 2.3.4
- **Severity:** CRITICAL
- **Description:** The target is running vsftpd version 2.3.4. This specific version contains a well-known, malicious backdoor. If a username containing a smiley face 😊 is sent during the login process, the software automatically opens a command shell on port 6200, allowing an unauthenticated attacker to execute commands.

3. Exploit Simulation

Tool Utilized: Metasploit Framework

Exploitation Methodology:

1. Launched the Metasploit console and searched for the identified vulnerability.
2. Loaded the specific exploit module: `exploit/unix/ftp/vsftpd_234_backdoor`.
3. Configured the target parameters (`RHOSTS` set to 10.0.2.15).
4. Configured the local host listener (`LHOST`) to capture the reverse connection.
5. Executed the exploit, which successfully triggered the backdoor and established a Meterpreter session.
6. Dropped into a system shell to verify privileges.

Proof of Compromise (PoC): The exploit was successful. System commands (`whoami`, `id`, `hostname`) were executed, confirming that the attacker gained absolute **root** control over the `metasploitable` server.

[illegible]

4. Mitigation and Remediation Plan

To secure the server and prevent this attack from happening in a production environment, the following steps must be taken immediately:

- **Immediate Action (Containment):** Stop and disable the `vsftpd` service immediately to close the active backdoor.
 - Command: `sudo service vsftpd stop`
- **Patch Management (Eradication):** The current version (2.3.4) must be uninstalled. If FTP is strictly required for business operations, install the latest, stable, and verified version of `vsftpd` from an official repository.
- **Protocol Hardening (Long-Term Fix):** Standard FTP transmits data (including passwords) in cleartext. The organization should deprecate FTP entirely and replace it with **SFTP (SSH File Transfer Protocol)**, which uses encrypted connections.
- **Network Access Control:** Implement strict firewall rules (e.g., using `iptables` or UFW). Port 21 should not be open to the public internet; it should only be accessible to whitelisted, authorized IP addresses via a VPN.
